

CactAI

Accountability-based security for small teams

A cactus doesn't chase you. It just makes touching it a bad idea.



The breach that was warned about

Dec 2020

Pentest finds an SQL injection hole

Unfixed

The developer never patched it

Feb 2021

4,625 students' data for sale on the dark web

\$10,000

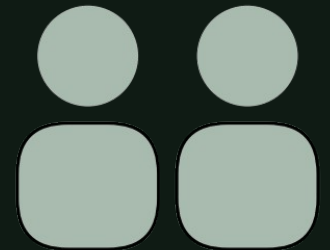
PDPC fine. The company learned of it from the regulator

“The vulnerability was left unfixed until the Incident happened.”

Missing response, not missing alert.

The problem

- Singapore SMEs and private schools hold lots of personal data, with one or two IT staff
- No 24/7 security team, so alerts pile up and get ignored (alert fatigue)
- **PDPA fines:** up to S\$1M or 10% of Singapore turnover, whichever is higher
- After a breach, no one can prove who knew what, and when

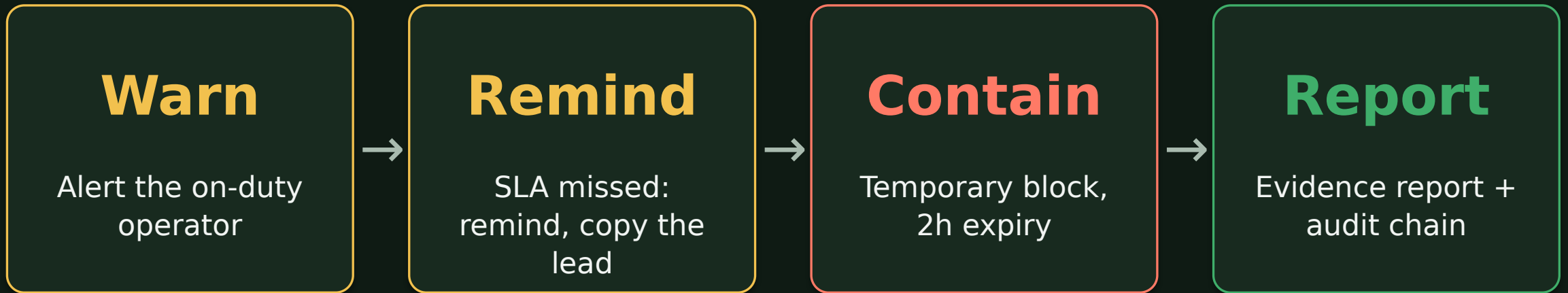


1-2 IT staff

THE IDEA

CactAI in one sentence

Scores your risk from 0 to 100 across web, database and OS, warns the people you choose, and past your own tolerance line applies a temporary, reversible fix, with a tamper-evident record.



TWO PRINCIPLES

CIA + NA

CIA

Protect the data

- Confidentiality
- Integrity
- Availability

NA

Prove who did what

- Non-repudiation: every alert and acknowledgement is hash-chained
- Authentication: every decision is tied to a named operator

Result: “I was never notified” is no longer an excuse.

HOW RISK IS SCORED

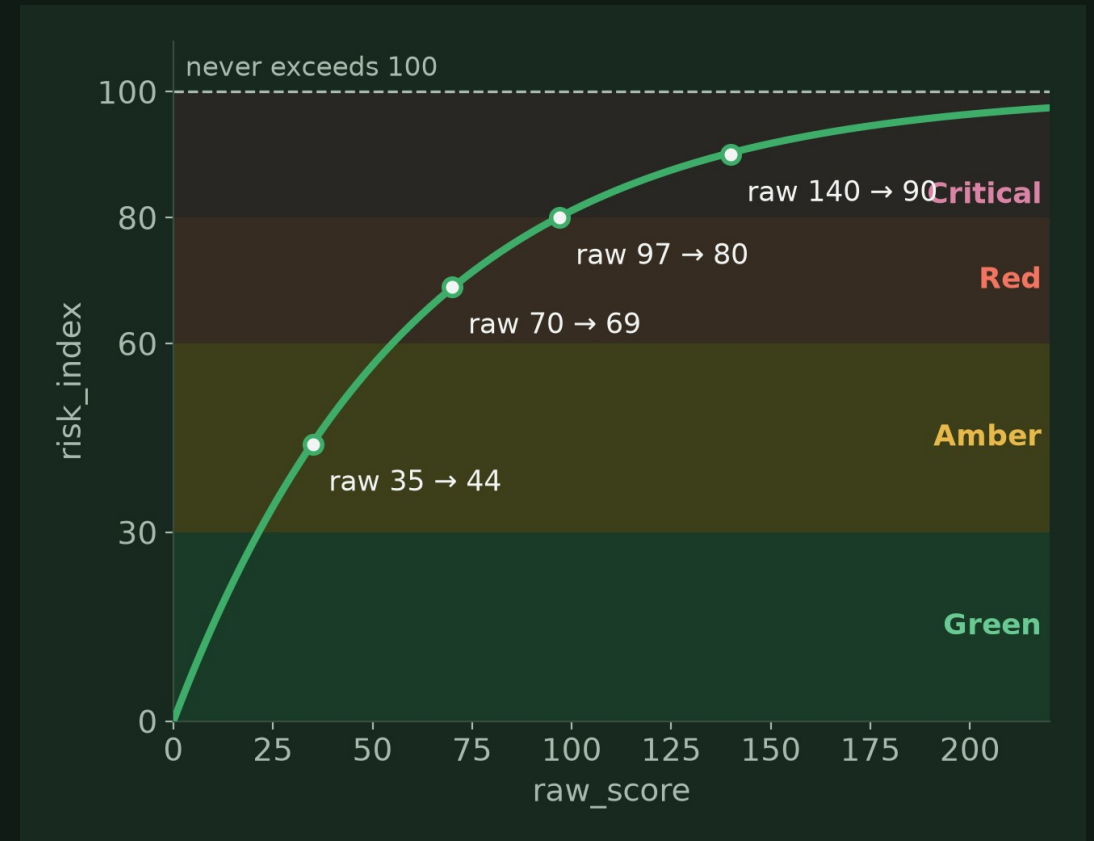
The 0 to 100 risk index

$\text{points} = \text{base} \times \text{confidence} \times \text{criticality}$

$\text{raw} = \sum \text{points} + \text{inaction penalty}$

$\text{index} = 100 \times (1 - e^{(-\text{raw} / 60)})$

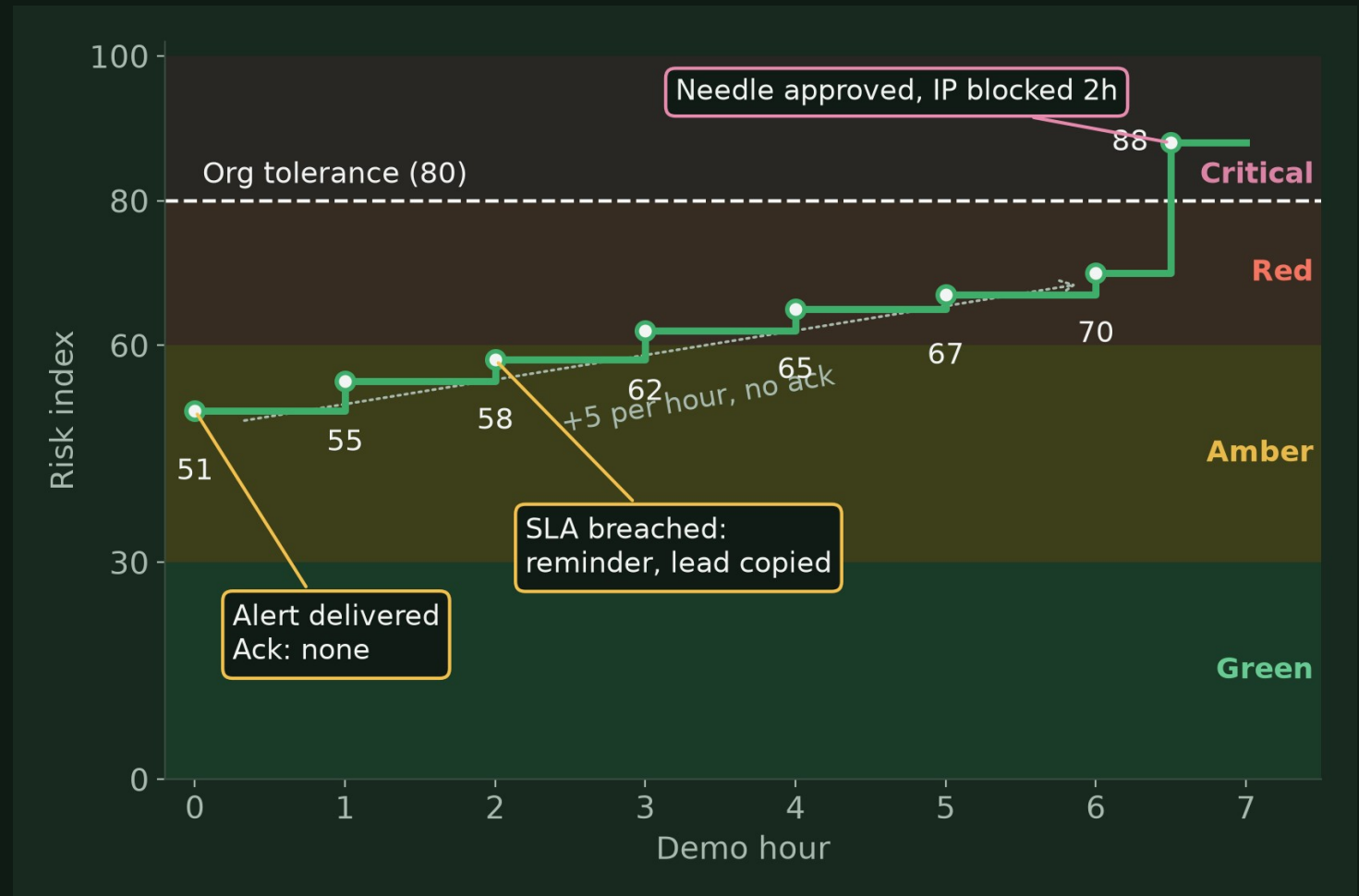
- **Inaction penalty:** +5 per hour unacknowledged, capped at +30
- **Bands:** Green 0-29 · Amber 30-59 · Red 60-79 · Critical 80-100
- **Threshold** is set by each organization



ESCALATION OVER TIME

Risk grows when nobody acts

- Brute force detected: index jumps into Amber
- Alert delivered, no acknowledgement: +5 every hour
- SLA (2h) breached: reminder, team lead copied
- SQL injection lands on a neglected system: crosses 80, Needle approves a 2h block



WHAT YOU WILL SEE

Live demo

- Lab student portal with synthetic member data, all on localhost
- Brute force → classified → operator alert ignored
- Inaction penalty climbs → SQL injection → crosses 80
- Needle approves → IP blocked for 2h → evidence report → a human decides



The Security Evidence Report

Responsible entity	On-duty operator and shift
SLA violation	Overdue by 4h 30m (policy 2h)
Timeline	Detected → alert delivered → reminder → threshold crossed
Acknowledgement	Ack: none
Forced action	IP blocked, 2h expiry, approved by Needle

#41 alert delivered



#42 Needle approved

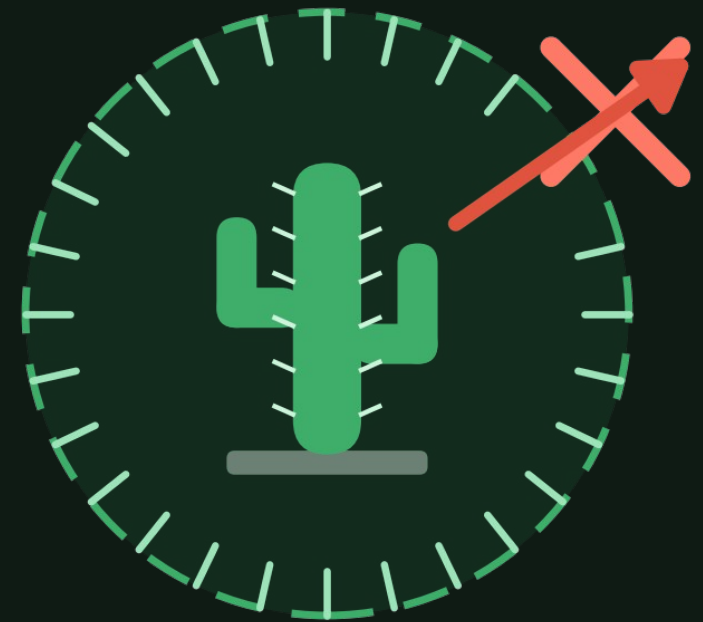


#43 operator rollback

✓ **chain valid**

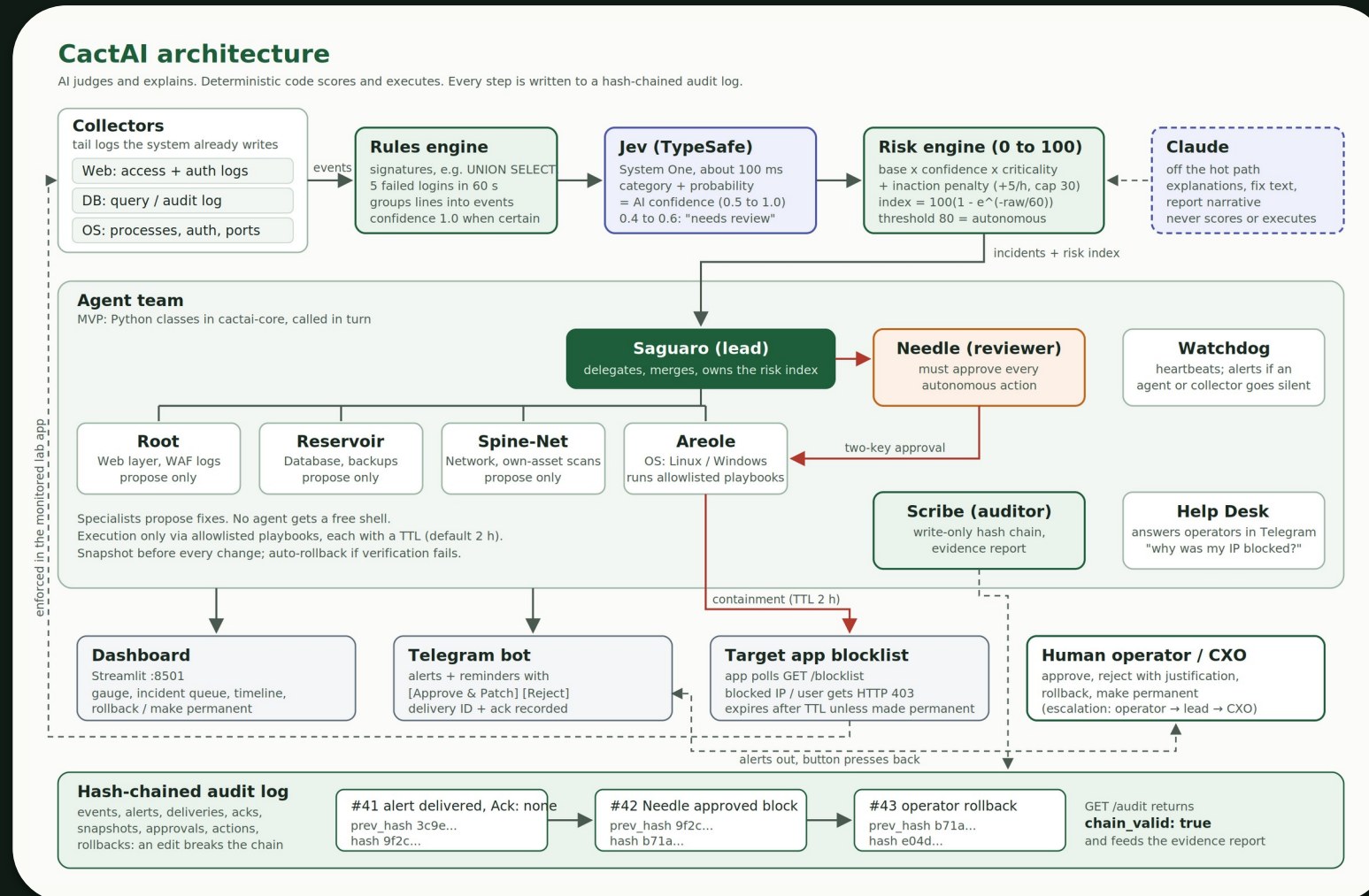
Ethics: no hack back

- **CactAI never attacks back.**
- Hacking back is a crime in Singapore: Computer Misuse Act s3 (access), s5 (modification), s7 (obstruction)
- Attacker IPs are often spoofed or hijacked innocent machines
- **Our “prick”:** block, tarpit, honeypots and honeytokens, evidence to SingCERT or the police



HOW IT FITS TOGETHER

Agent architecture



Roadmap and team

Now (MVP)

- Web, DB and OS collectors
- Rules → Jev → fallback classifier
- Cyanide AI planner + Needle two-key rule
- Blocklist containment with 2h TTL
- Evidence report + hash chain

Erick Sientaro

Developer

Next

- Real firewall blocking (iptables, netsh)
- Tarpit, honeypots, honeytokens
- Windows Event Log agent
- Cloud config scan (S3, security groups)

Ishmail

CEO, pitch

Later

- Single-binary collectors
- Agents as separate services
- Pilot with a Singapore private school

Hozen

Slides and sources

SOURCES

References

- PDPC, Breach of the Protection Obligation by ChampionTutor Inc. (Private Limited), DP-2103-B7984, 14 Oct 2021
- PDPC, Guide on Active Enforcement (revised 1 Oct 2022): financial penalties under PDPA s48J
- Computer Misuse Act 1993 (2020 Rev. Ed.), sections 3, 5 and 7, Singapore Statutes Online
- TypeSafe System One (Jev) documentation, docs.typesafe.ai
- Code and plan: github.com/RexGuard/cactai · rexguard.github.io/cactai